מחלקת תקשוב · רשתות · דף הנחיה למדריך

Domain, אימות, הצפנה ותעודות

זהות מנוהלת ב-Windows, הצפנה סימטרית ואסימטרית, תעודות ו-TLS

55 דקות	17	שטח
משך מומלץ	שקופיות כולל שער	רמת המיקוד

מותאם לטכנאי שטח · סביבת Windows מנוהלת

לפני שמתחילים

שטח	17	55 דקות
רמת המיקוד	שקופיות כולל שער	משך מומלץ

מטרת השיעור

לראות איך התחנה מאתרת DC, מאמתת משתמש, בודקת תעודה ומקימה חיבור TLS, ועל אילו תשתיות כל שלב נשען.

רמת ההבנה הנדרשת

מספיק שהחניך יפריד בין אימות להרשאה ובין הצפנה סימטרית לאסימטרית, ויכיר תעודה, Cipher Suite ו-TLS Handshake ברמה שמאפשרת לאבחן תקלה.

הכנה מראש

- ודאו שהקהל מכיר DNS, כתובת ו-Gateway מהשיעור הקודם.
- הכינו דוגמה להודעת תעודה או כניסה מוכרת, בלי פרטים רגישים.
- עברו מראש על רצף ה-TLS Handshake. בכיתה מסבירים את סדר השלבים ואת התקלות, בלי לפרק כל הודעה.

היקף השיעור

השיעור עוקב אחרי כניסת משתמש וחיבור TLS ומראה על אילו תשתיות הם נשענים. ניהול Active Directory, GPO או CA לא נכלל.

חלוקת זמן מוצעת

חלק	מה מעבירים	דקות
פתיחה	Domain כגבול זהות	5
AD, DNS והצטרפות	אובייקטים, איתור DC וחשבון מחשב	9
אימות והרשאה	Kerberos, כרטיסים וזמן	10
סוגי הצפנה	תפקיד ההצפנה האסימטרית והסימטרית	8
תעודות ומשא ומתן	שרשרת אמון ו-Cipher Suite	10
TLS Handshake	רצף ההודעות ומשפחות תקלה	10
סגירה	שרשרת התלות	3

שאלת פתיחה

כיצד שען שגוי יכול לגרום לכניסה להיכשל גם כשהסיסמה נכונה והרשת זמינה?

Domain מחבר זהויות ומדיניות; DNS מאפשר לתחנה לאתר אותו

Active Directory מחזיק משתמשים, מחשבים, קבוצות ומדיניות. Domain Controller מספק שירותי זהות, ו-DNS מאתר אותו. Domain Join יוצר חשבון מחשב וערוץ מאובטח.

ישות	תפקיד ב-Domain
Domain Controller	DNS · זהות · מדיניות
משתמש	חשבון Domain
תחנה	חשבון מחשב
קבוצה	הרשאות
שרת	שירות מוגן

השייכות ל-Domain נקבעת בניהול ובאמון. VLAN או Subnet לא משנים אותה.

DNS ציבורי בתחנה

DNS ציבורי יכול לאפשר גלישה ועדיין להפיל Domain, כי התחנה לא מאתרת דרכו את ה-DC.

רצף

DNS מתאים ← איתור DC ← חשבון מחשב ← ערוץ מאובטח ← קבלת מדיניות.

מה הטכנאי צריך לזהות

על הטכנאי להכיר את אובייקט המחשב ולהבין מה קורה לתחנה כשהחשבון נמחק או שהסוד שלו לא תואם. DNS שגוי הוא אחת הסיבות המרכזיות לכך שכתובת ה-IP עובדת אך הכניסה ל-Domain נכשלת.

אימות, הרשאות וזמן ב-Domain

אחרי שהמשתמש זוהה, ההרשאות למשאבים נבדקות בנפרד. Kerberos משתמש בכרטיסים המוגבלים בזמן. פער שעון משמעותי גורם לדחייה, ו-Group Policy יכולה לשנות שירותים, חומת אש, תעודות והרשאות.

שלב	תפקיד
DNS	איתור DC
זמן	תוקף כרטיס
Kerberos	אימות
הרשאה	קבוצות

לפני האימות בודקים DNS וזמן. ב-TLS צריך גם תעודה ושרשרת אמון תקינות.

בדיקת התעודה

Certificate: שם · תוקף · מנפיק · שרשרת. ב-TLS קודם מאמתים את השרת ואז מצפינים את התעבורה.

טעות אבחון נפוצה

תקלה בהרשאה, כמו משתמש שלא רואה תיקייה משותפת, אינה בהכרח תקלה בסיסמה או בקשר ל-DC. ב-Group Policy מספיק לדעת לאסוף gpresult ולבדוק אם המדיניות התקבלה.

שאלת ביניים

משתמש נכנס לתחנה אך אינו פותח תיקייה: האם זו בהכרח בעיית סיסמה?

הצפנה אסימטרית ב-Handshake, סימטרית לתעבורה

מפתח ציבורי ניתן להפצה והמפתח הפרטי נשאר אצל בעליו. במהלך ה-Handshake הצדדים מאמתים זהות וגוזרים סוד משותף; לאחר מכן אותו מפתח Session זמני משמש להצפנה סימטרית מהירה.

סוג	מפתחות	שימוש
אסימטרית	Public להפצה, Private נשאר אצל הבעלים	זהות והסכמה על סוד משותף
סימטרית	אותו מפתח Session לשני הצדדים	הצפנת המידע עצמו, כי היא מהירה לתעבורה

ניסוח שגוי נפוץ

אין לתאר את מפתח ה-Session כקובץ שנשלח לצד השני; שני הצדדים גוזרים אותו בלי לחשוף אותו ברשת.

יעדי האבטחה

TLS נותן סודיות, שלמות ואימות זהות. הצפנה לבדה אינה מוכיחה שהגענו לשרת הנכון.

תעודה, שרשרת אמון ובחירת Cipher Suite

הלקוח בודק שם, תוקף, מנפיק ושרשרת עד Root מהימן. במקביל הלקוח מציע אפשרויות, והשרת בוחר Cipher Suite ששניהם תומכים בו. ב-TLS 1.3 הבחירה מתארת את הצפנת התעבורה ואת ה-Hash.

רכיב	ערך	תפקיד
הצעת הלקוח	TLS_AES_128_GCM_SHA256 · TLS_AES_256_GCM_SHA384 · TLS_CHACHA20_POLY1305_SHA256	ClientHello מציע את האפשרויות הנתמכות
בחירת השרת	TLS_AES_128_GCM_SHA256	ה-Cipher Suite ששני הצדדים תומכים בו
הצפנה	AES_128_GCM	הצפנה סימטרית + שלמות
Hash	SHA256	גזירת מפתחות

ב-TLS 1.3, גרסה, Key Exchange וחתימה מוסכמים לצד ה-Cipher Suite.

מה חשוב לטכנאי

את שמות האלגוריתמים לא צריך לזכור. צריך לדעת שכשל התאמה יכול להפיל את החיבור לפני שעובר מידע יישומי.

שרשרת האמון

אמון נבנה מהתעודה דרך מנפיקים עד Root המותקן מראש במאגר האמון של המכשיר. חוליה חסרה, כמו Intermediate שלא הותקן, או Root שאינו מהימן, שוברים את השרשרת.

מידע יישומי עובר רק בסוף ה-Handshake

ClientHello ו-ServerHello מסכימים על פרמטרים ומחליפים חומר לגזירת מפתחות. השרת מציג תעודה ומוכיח בעלות על המפתח הפרטי; שני הצדדים גוזרים מפתחות Session ומאשרים Finished.

שלב	כיוון	מה עובר
1	מהלקוח	ClientHello: גרסה, Cipher Suites, key share
2	מהשרת	ServerHello: ההצעה שנבחרה, key share
3	מהשרת	Certificate, CertificateVerify
4	משותף	אימות וגזירת מפתחות Session, בלי לשלוח אותם ברשת
5	מהשרת	Finished
6	דו-כיווני	Application Data מוצפנת סימטרית

מינוח

SSL הוא שם ישן שנשאר בשפה היומיומית. הפרוטוקול המודרני הוא TLS.

בתקלת TLS בודקים זמן, שם, שרשרת אמון ומשא ומתן.

משפחת תקלה	דוגמה אופיינית
זמן או תוקף	שעון או תאריך מערכת שגוי
שם לא תואם	הפנייה נעשית בשם שונה מזה שרשום בתעודה
שרשרת אמון חסרה	Intermediate או Root שאינם מותקנים או אינם מהימנים
חוסר התאמה במשא ומתן	גרסת TLS או Cipher Suite שאינם משותפים לשני הצדדים

מהלך המצגת ודגשים למדריך

#	נושא ותמצית	#	נושא ותמצית
1	**שער.** זהות ו-TLS נשענים על תשתית	2	**Domain ו-DC.** להבדיל בין Domain ל-DNS Domain
3	**אובייקטים.** משתמשים, מחשבים, קבוצות ומדיניות	4	**DNS של Domain.** איתור DC באמצעות רשומות
5	**Domain Join.** נוצר חשבון מחשב ואמון	6	**אימות והרשאה.** תקלת הרשאה אינה בהכרח תקלת סיסמה
7	DNS **Kerberos.** וזמן נדרשים לפני הכרטיס	8	**זמן.** גם תעודה נראית "פגה" או "טרם בתוקף"
9	**Group Policy.** הטכנאי אוסף gpresult	10	**יעדי אבטחה.** הצפנה לבדה אינה מוכיחה זהות שרת
11	**סוגי הצפנה.** מפתח ה-Session נגזר בשני הצדדים	12	**תעודה.** שם, מפתח, מנפיק ותוקף
13	**שרשרת אמון.** Intermediate יכול להגיע עם השירות	14	**Cipher Suite.** כשל התאמה מפיל את החיבור לפני מידע
15	Hello **TLS Handshake.**, תעודה, מפתחות ו-Finished	16	**תקלות TLS.** הודעת שגיאה מלאה ותאריך המערכת
17	**תלות מערכתית.** רשת, DNS, זמן, זהות ו-TLS		

מילון קצר למדריך

Domain	גבול ניהולי של זהות ואמון	**CA**	גורם שחותם על תעודה
Kerberos	אימות מבוסס כרטיסים	**Certificate**	קישור זהות למפתח ציבורי
אסימטרית	זוג מפתחות ציבורי ופרטי	**Handshake**	הסכמה ואימות לפני מידע יישומי
סימטרית	אותו מפתח זמני לשני הצדדים	**Cipher Suite**	שילוב הצפנה ו-Hash שנבחר

שאלת סיום

השרת נגיש ב-IP ובפורט אך TLS נכשל. מה בודקים לפני שמאשימים את היישום?

טעות נפוצה

חניך מסביר שהתעודה "מצפינה את התעבורה". התעודה קושרת שם למפתח ציבורי; את התעבורה מצפין מפתח Session סימטרי.